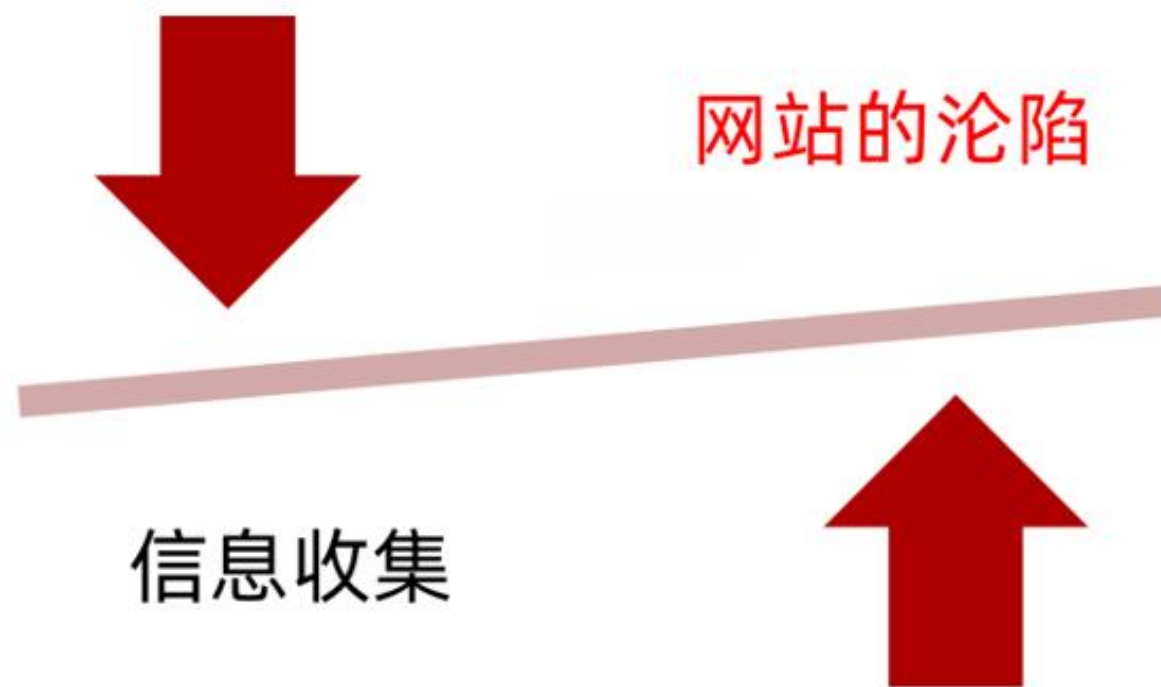




信息收集



主要内容



网站的沦陷



网站的沦陷



不了不了，这个真的伤身体

信息收集

信息收集不管是平时的渗透项目还是挖掘SRC，信息收集都是重中之重。



信息收集

正面信息收集

组成网站的信息：网站页面、域名信息、目录等

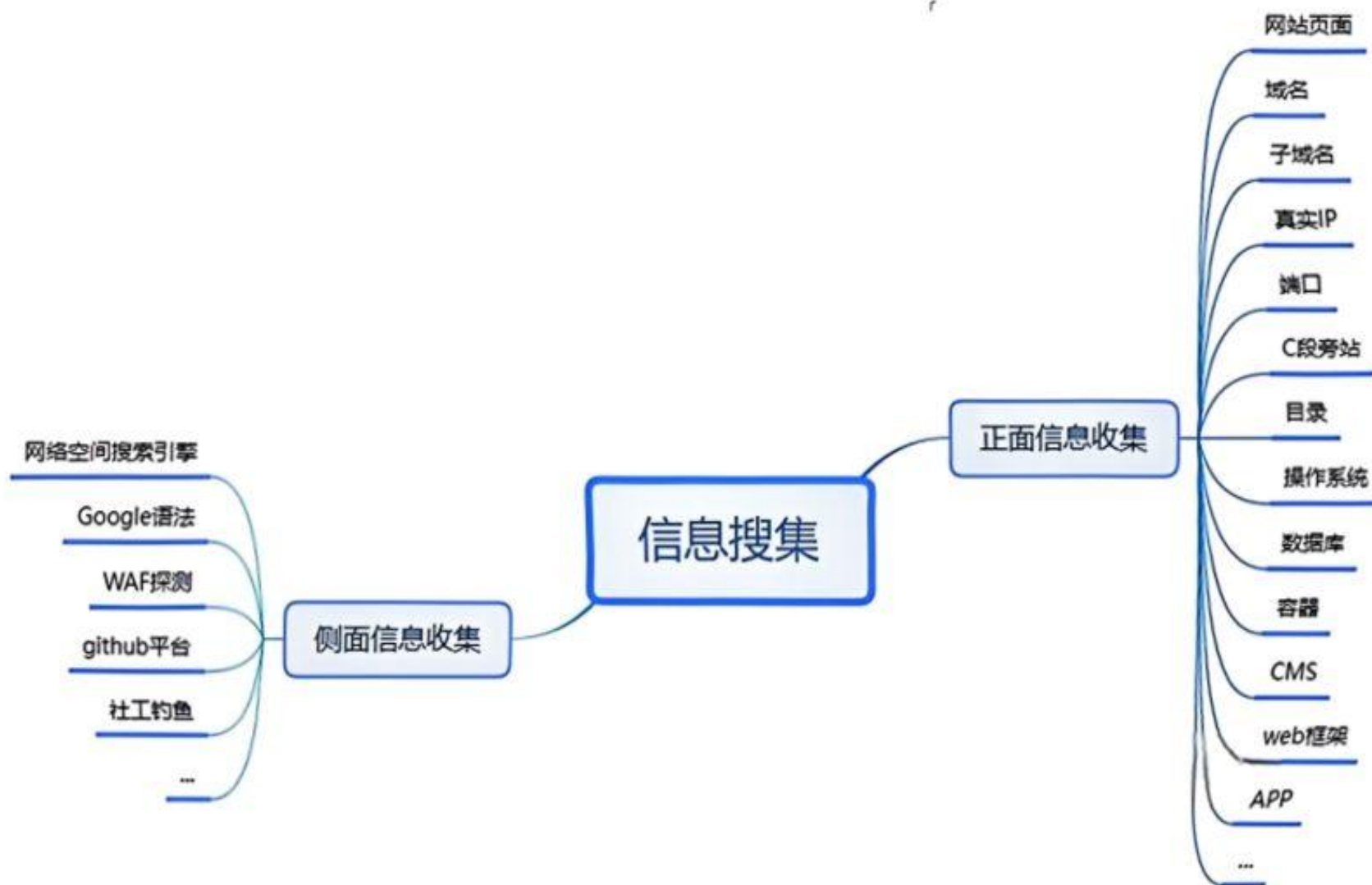
侧面信息收集

利用第三方的服务：Google、fofa、shodan



给你一个眼神
你应该懂我意思吧

重点区域



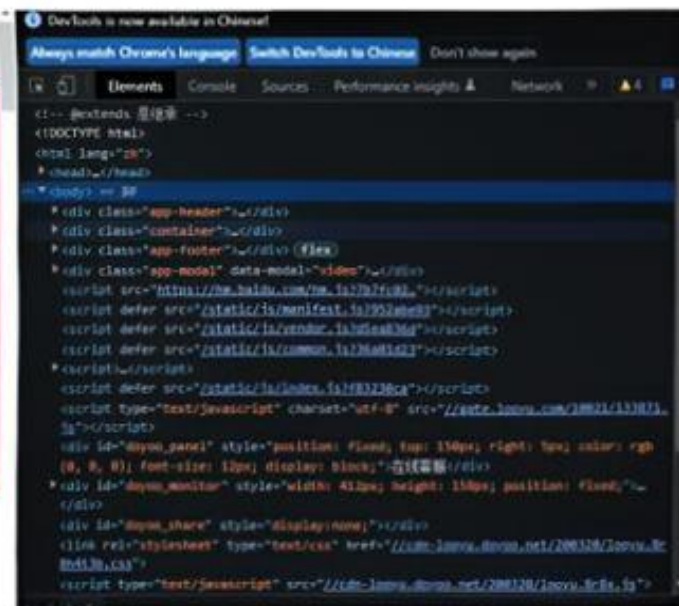
网站页面



看黑板啊

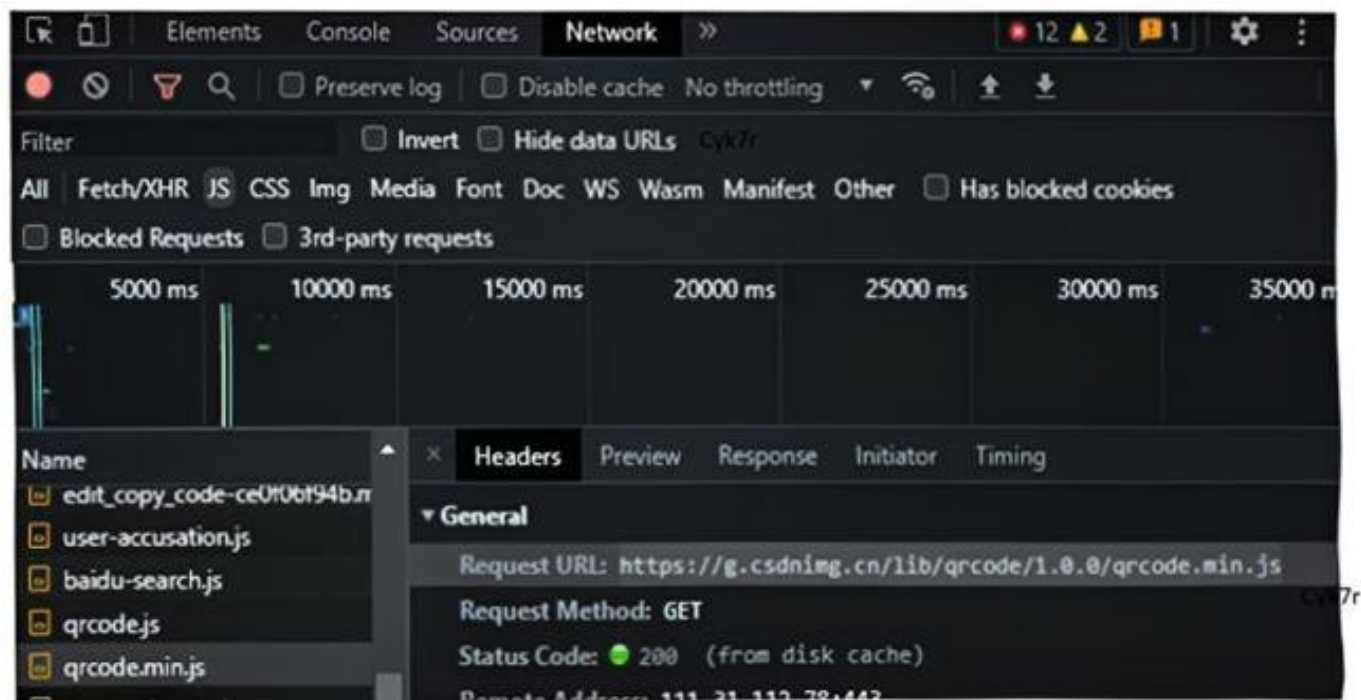
网站页面

从网站的URL观察，有些URL会暴露网站使用的脚本语言、网站框架。再可能正使用的OA、关于公司的联系方式（邮箱、电话号码、工作地点等）、备案号、营业执照图、后台登录接口、友情链接、某些二维码等。页面源代码、网络连接中的js文件。



小技巧

右键查看JS源码，可能会发现被注释的账号密码、接口、token、真实IP、开发环境。



There's no place like

127.0.0.1

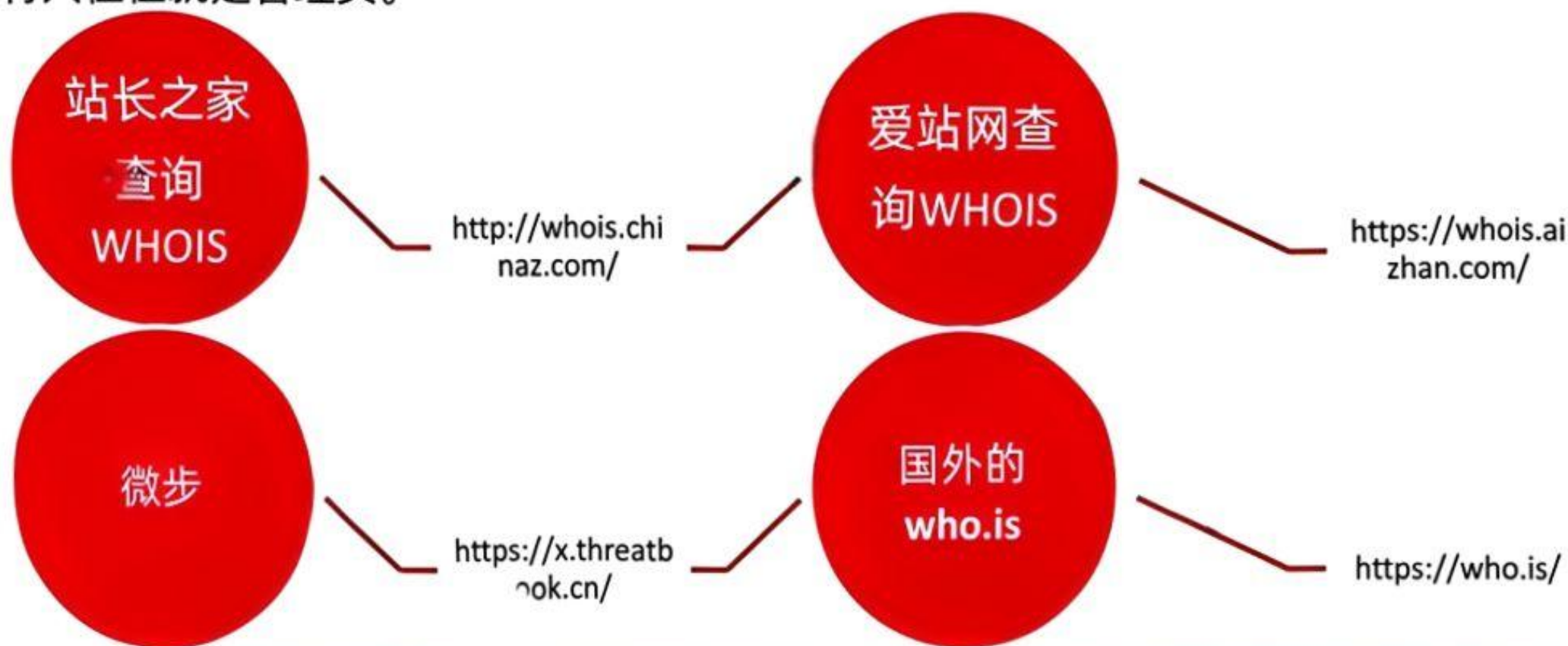
域名收集



看黑板啊

Whois查询

在Whois查询中，得到注册人的姓名和邮箱信息通常对测试个人站点非常有用，因为我们可以借助搜索引擎和社交网络挖掘出域名所有人的很多信息。对中小站点而言，域名所有人往往就是管理员。



ICP备案查询网

ICP 备案查询可以查询网站的 ICP（互联网内容提供商）备案信息，包括备案号、网站名称、备案日期等。

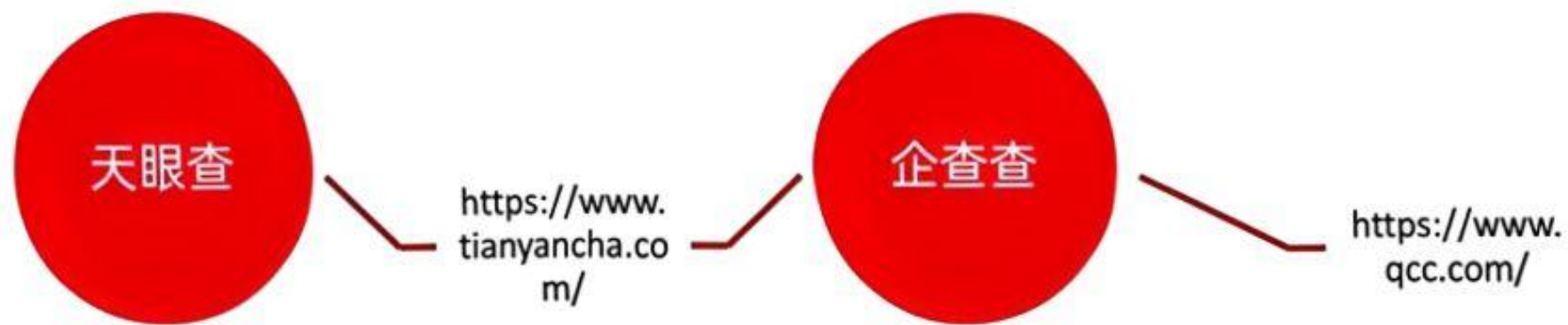


ICP备案查
询网

<https://www.beianx.cn/>

公司备案查询

根据ICP备案可以获取的企业名称，在通过公司备案可以获取目标企业的微信公众号、微博、备案站点、APP、软件著作权等信息。



网站备案查询案例



```
C:\Users\user>ping www.yang.com

正在 Ping www.yang.com [12.34.56.78] 具有 32
来自 12.34.56.78 的回复: 字节=32 时间=85ms TTL=49
来自 12.34.56.78 的回复: 字节=32 时间=112ms TTL=49

12.34.56.78 的 Ping 统计信息:
    数据包: 已发送 = 2, 已接收 = 2, 丢失 = 0 (0% 丢失),
    往返行程的估计时间(以毫秒为单位):
```

SEO综合查询

爱站-SEO综
合查询

<https://www.aizhan.com/cha/>

子域名收集



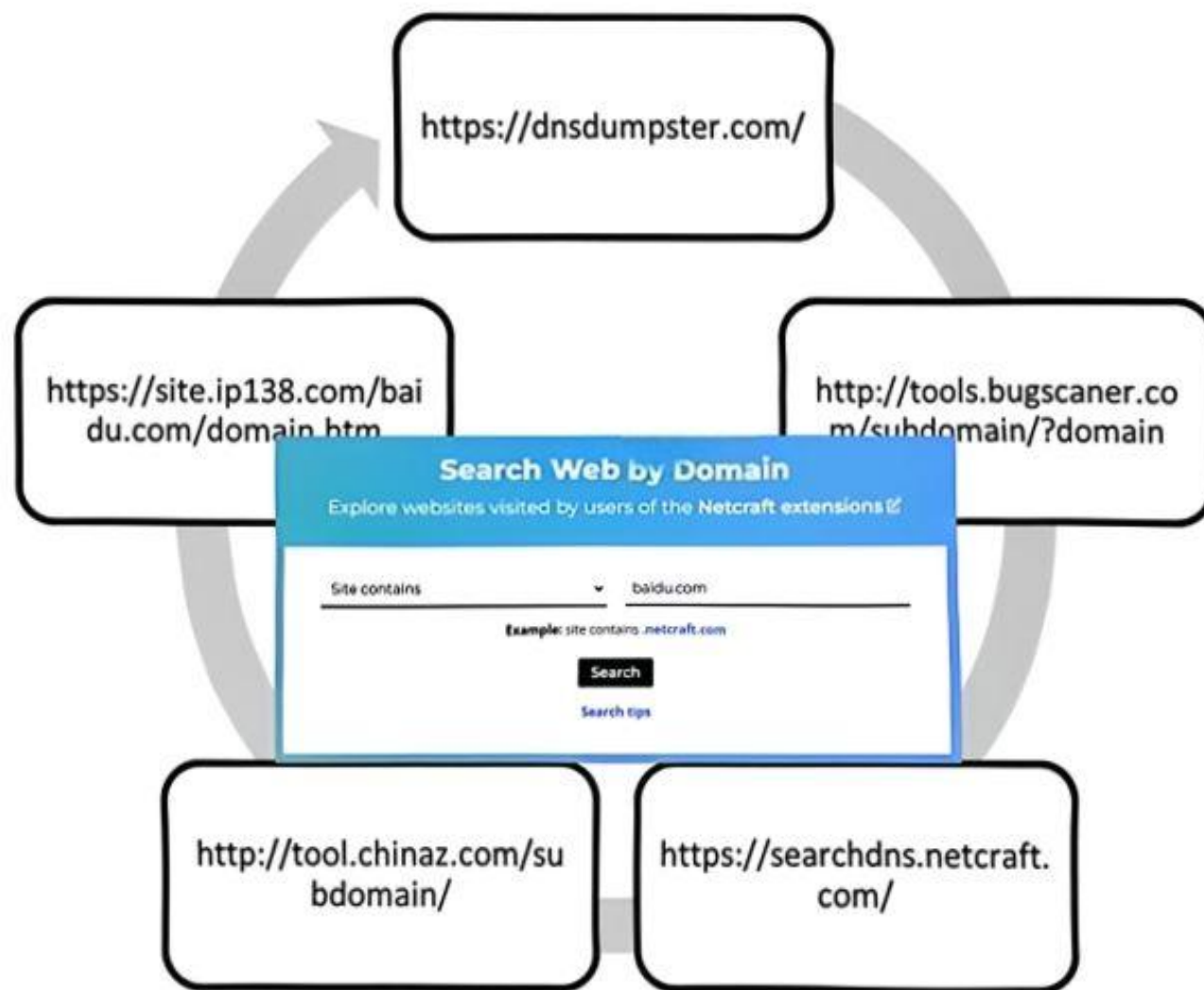
看黑板啊

子域名收集(挖掘)

大厂商的SSL证书一般都是一证多用，根据证书透明日志这个特性，可以得知一些子域名。



在线搜集



用于子域名检测的工具主要有Layer、K8、subDomainsBrute等。重点推荐OneForAll。<https://github.com/shmilylty/OneForAll.git>

```
C:\Users\XuanJian\Desktop\OneForAll-0.4.5>python3 oneforall.py --target https://www.*.bilibili.com/ run
OneForAll is a powerful subdomain integration tool

[Progress Bar] {v0.4.5 -dev}
[Progress Bar] git.io/fjHT1

OneForAll is under development, please update before each use!

[*] Starting OneForAll @ 2022-09-22 14:04:20

14:04:20.541 [INFOR] utils:523 - Checking dependent environment
14:04:20.541 [INFOR] utils:535 - Checking network environment
14:04:20.807 [INFOR] utils:546 - Checking for the latest version
14:04:21.151 [INFOR] utils:570 - The current version v0.4.5 is already the latest version
14:04:21.151 [INFOR] oneforall:243 - Start running OneForAll
14:04:21.151 [INFOR] oneforall:248 - Got 1 domains
14:04:21.167 [INFOR] wildcard:108 - Detecting bilibili.com use wildcard dns record or not
14:04:51.195 [ALERT] wildcard:123 - The domain www.bilibili.com disables wildcard
14:04:51.195 [INFOR] collect:44 - Start collecting subdomains of bilibili.com
14:04:51.273 [INFOR] module:63 - QueryMX module took 0.0 seconds found 0 subdomains
14:04:51.320 [INFOR] module:63 - QuerySPF module took 0.0 seconds found 0 subdomains
14:04:51.336 [INFOR] module:63 - NSECCheck module took 0.1 seconds found 2 subdomains
14:04:51.351 [INFOR] module:63 - QuerySOA module took 0.1 seconds found 0 subdomains
```

There's no place like

127.0.0.1



看黑板啊

查IP

CDN-内容分发式服务

内容分发网络（CDN）通过互联网互相连接的电脑网络系统，利用最靠近用户的服务器，更快、更可靠地将网络内容传递给用户，提高网站的访问速度和稳定性。

根据用户所在地
区来确定访问的
缓存服务器



CDN-内容分发式服务

通过每个地区ping的结果得到IP大多都不太一样或者规律性很强就是挂载CDN。

<http://ping.chinaz.com/>

<https://www.17ce.com>

监测点	ISP	省份	解析IP	解析IP所在地	Http状态
共199个点	10个	共40个	共2个独立IP	共2个独立节点	有非200状态
内蒙古通辽市电信	电信	内蒙古	110.242.68.66	中国河北保定联通	200
江苏无锡市移动	移动	江苏	39.156.66.10	中国北京移动	

绕过CDN



旁站、C段

找到目标的真实IP以后，查询IP定位，查询IP地址的C段和旁站情况。

<http://www.webscan.cc/>都可以

<http://s.tool.chinaz.com/same>旁站

<http://www.114best.com/ip/>旁站

<https://chapangzhan.com>旁站



There's no place like

127.0.0.1

端口扫描



看黑板啊



`nmap -sS -v -sV -p 1-65535 IP` # ping目标有回复时

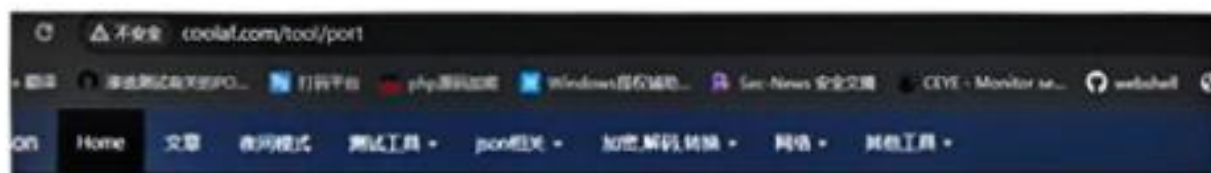
`nmap -sS -v -sV -p 1-65535 -Pn IP` # ping目标没有回复时

vps上装nmap，用它来扫端口，一般1个IP全端口3-5分钟扫完

```
(root@kali) - [~/桌面]
# nmap -h
Nmap 7.92 ( https://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
```


在线工具

在线的端口扫描网站<http://coolaf.com/tool/port>



在线检测域名或者ip的端口是否开放

www.baidu.com

80,21,22,23,25,53,110,443,1433,1863,2289,3306,5631,5632,5000,8080,9090

端口扫描

域名	端口	端口状态	ip
www.baidu.com	80	开放	110.242.68.4
www.baidu.com	53	关闭	110.242.68.4
www.baidu.com	21	关闭	110.242.68.4
www.Daidu.com	22	关闭	110.242.68.4
...	...	...	...

远程管理端口



22

利用弱口令/暴力破解，
获取目标主机权限。



5900

VNC拒绝服务攻击
(CVE-2015-5239)

VNC权限提升 (CVE-
2013-6886)



3389

1、弱口令或暴力破解。
2、CVE-2019-0708

Web中间件/服务端口



1090/1099

JAVA RMI 反序列化远程命令执行漏洞。



7001

弱口令、SSRF、反序列化漏洞。



8000

JDWP 远程命令执行漏洞。



8080

1、弱口令登录控制台，上传war包。

2、幽灵猫

3、PUT文件上传



8080

1、未授权访问控制台，远程部署木马。

2、反序列化导致远程命令执行等。



50070

1、未授权访问可下载任意文件。

2、未授权访问RCE

数据库端口



1433

- 1、注入、爆破
- 2、差异备份getshell、SA账户xp_cmdshell提权。



1521

- 1、注入、爆破
- 2、CVE-2018-3004
- 3、使用 SQL 语句创建函数执行系统命令。



3306

- 1、利用日志写入webshell。
- 2、udf提权、mof提权等。



6379

- 1、绝对路径写webshell。
- 2、利用计划任务执行命令反弹shell。
- 3、公私钥认证获取root权限。
- 4、主从复制RCE

其他端口



21

- 1、匿名登录或弱口令
- 2、嗅探ftp用户名和密码
- 3、第三方软件提权



139、445

- 1、爆破启IPC漏洞
- 2、缓冲区溢出导致远程代码执行



Rsync

- 1、rsync未授权访问漏洞。

There's no place like

127.0.0.1



看黑板啊

网站信息

系统类型

将首页或者其他页面通过修改大小写辨别网站所使用的系统：

区分大小写（页面报错）--Linux

不区分大小写（页面正常）--Windows



容器信息

Apache、Nginx、Tomcat 还是weblogic? 还是Struts2? 等等, 其次具体什么版本?
Nginx版本<0.83会有解析漏洞, IIS6.0会有文件名解析漏洞、IIS7.0会有畸形解析漏洞等。不同的web服务器版本, 存在着不同漏洞。

```
root@kali:~# whatweb 10.10.10.10
10.10.10.10 [200 OK] Apache[2.4.34], Cookies[PHPSESSID], Country[CHINA][CN], HTML5, HTTPServer[Apache/2.4.34 (codeit) PHP/7.2.9], IP[10.10.10.10], JQuery[1.11.2], PHP[7.2.9], Script[javascript], Title[👉👉👉], X-Powered-By[PHP/7.2.9]
```

识别出相应的CMS或者OA，查找与其相关的漏洞，可找到该CMS或者OA已经公布的漏洞进行利用，进一步渗透网站。

云悉<http://www.yunsee.cn/info.html>

潮汐指纹<http://finger.tideseccn.net/>

<http://whatweb.bugscaner.com/look/>



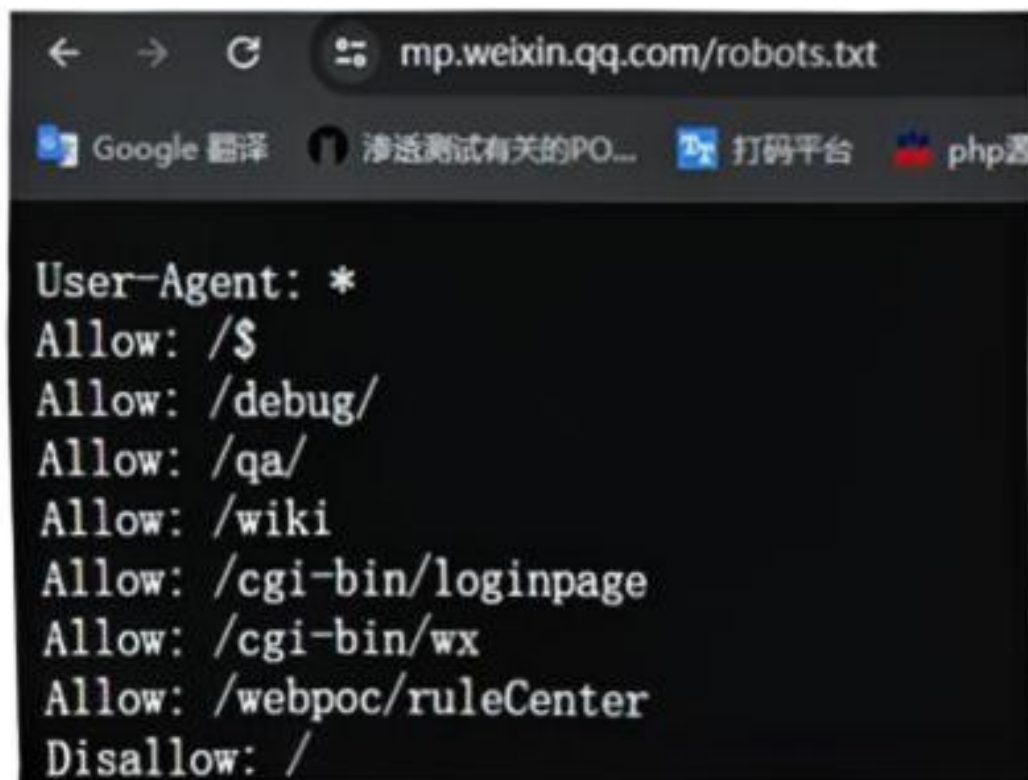
敏感信息

目录扫描也是要点，如果你能从目录中找到一些敏感信息，那么思路可能就会更宽一点。例如扫描出后台，备份文件，敏感文件，敏感目录或者其他敏感信息。

```
13:53:34] 200 - 3KB - /cms/cms/include/fckeditor/
13:53:34] 200 - 2KB - /cms/cms/include/
13:53:34] 200 - 4KB - /cms/cms/index.php.bak
13:53:34] 403 - 1KB - /cms/cms/install.asp
13:53:34] 403 - 1KB - /cms/cms/login.asp
13:53:34] 403 - 1KB - /cms/cms/Login.cgi
13:53:34] 403 - 1KB - /cms/cms/login.cgi
13:53:34] 403 - 1KB - /cms/cms/login.pl
13:53:34] 403 - 1KB - /cms/cms/Login.pl
13:53:35] 403 - 1KB - /cms/cms/logout.asp
13:53:35] 403 - 1KB - /cms/cms/logs.pl
13:53:35] 200 - 0B - /cms/cms/include/config.inc.php
13:53:35] 200 - 7KB - /cms/cms/index.php
13:53:35] 200 - 7KB - /cms/cms/index.PHP
13:53:35] 200 - 7KB - /cms/cms/INDEX.PHP
```


敏感信息

robots.txt 文件是专门针对搜索引擎机器人robot 编写的一个纯文本文件。我们可以在这个文件中指定网站中不想被robot访问的目录。或者让搜索引擎只收录指定的内容。



```
← → ↻ mp.weixin.qq.com/robots.txt
Google 翻译 渗透测试有关的PO... 打码平台 php源
User-Agent: *
Allow: /$
Allow: /debug/
Allow: /qa/
Allow: /wiki
Allow: /cgi-bin/loginpage
Allow: /cgi-bin/wx
Allow: /webpoc/ruleCenter
Disallow: /
```

不能直接浏览网页找到后台时，尝试下故意请求不存在的页面，让网页故意显示报错信息，查看网站真实路径，可以得到我们想要的后台地址信息。

HTTP Error 404.0 - Not Found

The resource you are looking for has been removed, had its name changed, or is temporarily unavailable.

Most likely causes:

- The directory or file specified does not exist on the Web server.
- The URL contains a typographical error.
- A custom filter or module, such as URLScan, restricts access to the file.

Things you can try:

- Create the content on the Web server.
- Review the browser URL.
- Create a tracing rule to track failed requests for this HTTP status code and see which module is calling SetStatus. For more information about creating a tracing rule for failed requests, click [here](#).

Detailed Error Information:

Module	IIS Web Core
Notification	MapRequestHandler
Handler	StaticFile
Error Code	0x80070002

Requested URL	http://[REDACTED]
Physical Path	D:\www\[REDACTED]
Logon Method	Anonymous
Logon User	Anonymous

通过七麦数据移动应用数据分析平台，去查找与网站配套的APP，对其APP以及APP交互的服务器进行测试。

深圳市腾讯计算机系统有限公司 Tencent Technology (Shenzhen) Company Limited QQ

APP ID: 448934866 类别: 社交 价格: 免费 内容: 10岁+ 2+125个评论 评分: 3.7 排名: 第3名 应用下载量: 224,413 最后更新: 2022-01-22

应用概述
应用详情
应用状态统计
版本记录
评分评论
开发应用

应用列表

#	应用	应用图标	应用名称	应用类别	应用版本	应用更新时间	应用最后更新时间
1	QQ	QQ	Tencent Technology (Shenzhen) Company Limited	社交	3.7	2022-01-22	2022-01-22
2	QQ同步助手-手机资料备份 换机数据恢复	QQ同步助手	Tencent Technology (Shenzhen) Company Limited	工具	1.19	2022-01-11	2022-01-11
3	QQ	QQ	Tencent Technology (Shenzhen) Company Limited	社交	3.7	2022-01-22	2022-01-22

微信公众号和小程序

通过微信搜索公众号并去关注，然后进去点击文章之类的去阅读原文，找到它的url后又可以去测试;小程序的测试也是模拟器抓包测试。

```
1 GET /webapi/PersonalData/BaseInfo/MyInfo?userId=1&userType=1 HTTP/1.1
2 Host:
3 Cookie: LoginUserInfo=
4 ASP.NET_SessionId=rw
5 LoginUserInfo: NBN
6 M
7 User-Agent: Mozilla/5.0 (Windows NT 6.0; Win64; x64; rv:42.0) Gecko/20100101 Firefox/42.0
8 MicroMessenger: 6.0.0.10
9 Language: zh-CN ABI/armv7l MINIPROG...
10 I-Request-With:
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: https://.../index.html
15 Accept-Encoding: gzip, deflate
16 Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
17 Connection: close
```

```
"DirectTeacherFlag":0,
"StaffStatus":0,
"EntryDate":null,
"EntryDateStr":"","
"SchoolID":2,
"UserRoles":null,
"RegisterWay":1,
"RowNum":0,
"LeaderFlag":0,
"AvatarAddress":"","/Upload/Image/UserPhoto/",
"GenderName":null,
"IsBinDingWeChat":0,
"UserID":1,
"UserType":1,
"LoginName":"","
"Pwd":null,
"NickName":null,
"Avatar":null,
"UserName":"","人",
"Gender":1,
"Phone":"","
```

There's no place like

127.0.0.1



看黑板啊

网络空间搜索引擎

网络空间搜索引擎

FOFA网络空间测绘搜索引擎，帮助我们以搜索的方式查找目标在公网上的互联网资产。



网络空间搜索引擎

title="目标名称" && region="xx省"&&icon_hash="-247388890"

cert="目标域名或者证书关键字" && region="xx省"

app="致远互联OA"&&title="目标名称"

((title="目标名称" || host="目标域名") && country="CN") && region!="HK"



Google 语句

Google语法是最强大的搜索手段之一，我们收集到一些敏感页面、敏感目录、网站内可下载的文件、可能出现的sql注入点和文件上传点、未授权访问页面等。



Intext

查找网页中含有xx
关键字的网站

Intext:管理员登录



Intitle

查找某个标题
intitle:后台登录



Filetype

查找某个文件类型
的文件

filetype:php



Inurl

查找url中带有某字
段的网站

inurl:php?id=

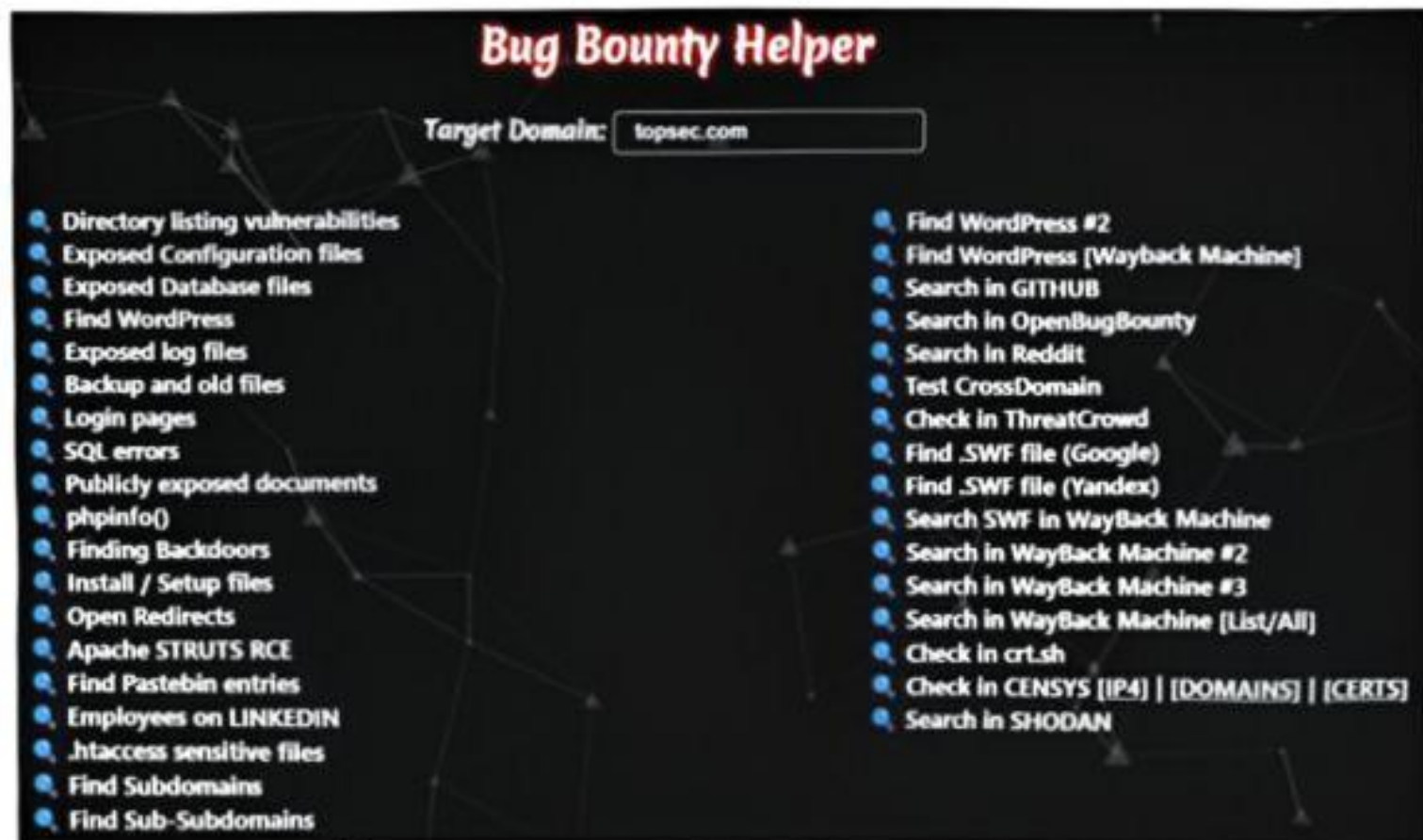


Site

在某域名中查找信
息

Site:目标站点

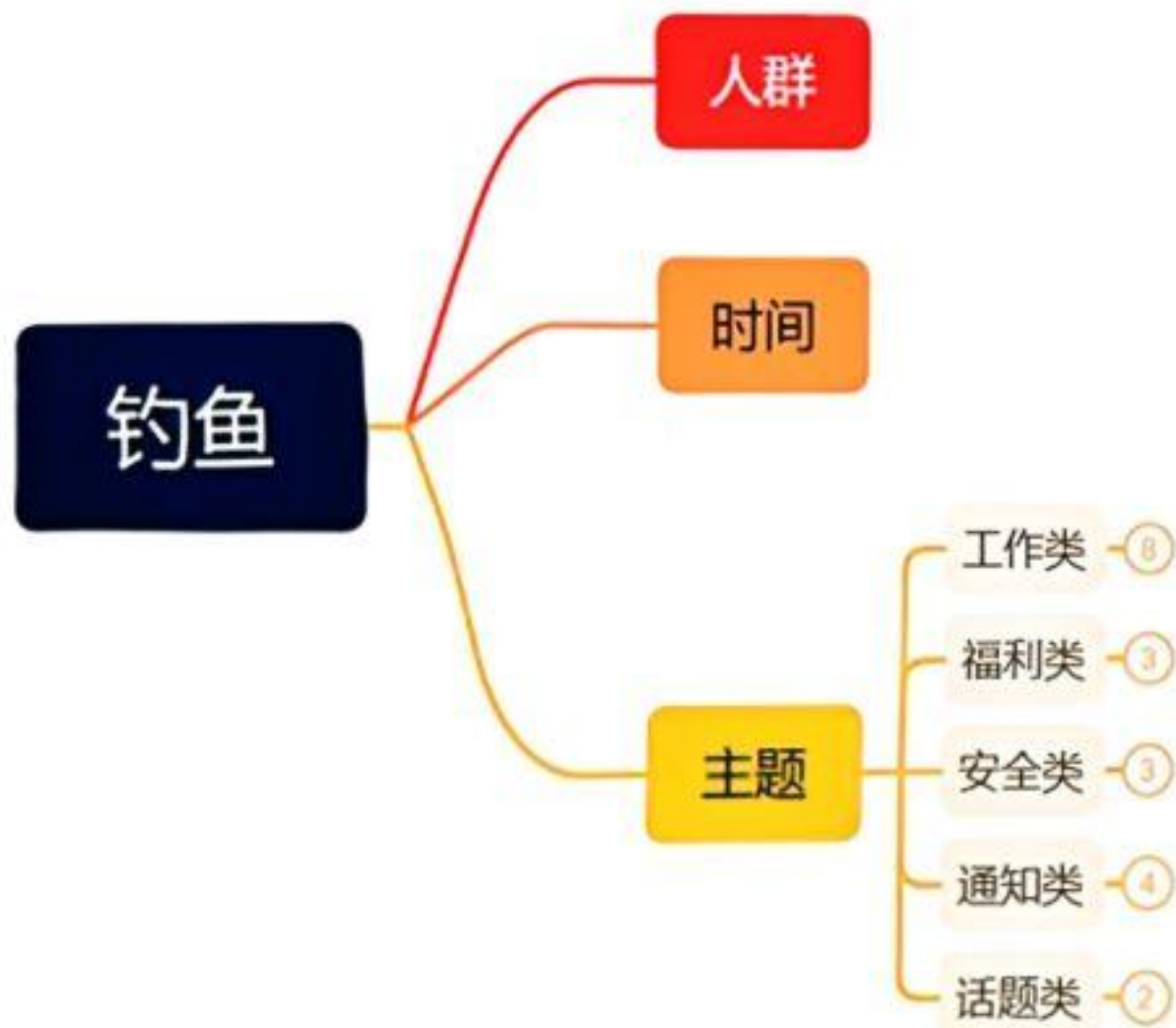
二开的谷歌语法搜索工具, <https://dorks.faisalrahmed.me/>





在代码共享平台上时常有代码泄漏，并且代码中时常包含服务器、数据库的地址帐号密码等敏感信息。





钓鱼案例1

杭州中电商科技有限公司文件

From 杭州中电商科技有限公司 <[redacted]>

☆ 下午 3:53

To [redacted]

[redacted]

[redacted]

尊敬的吴女士:

您好!

有关[redacted]补充医疗及意外伤害保险采购项目竞争性磋商文件澄清内容,详情请见附件。

如您有任何问题可与[redacted]科技有限公司服务代表联系。

联系地址: [redacted]

服务代表: [redacted]

电子邮件: [redacted]

王源

572.76 KB 1 个附件

↓

[redacted]有限公司附件.rar 572.76 KB

钓鱼案例2

猎头中国有限公司

猎头助理

职业方向: 猎头行业 · 猎头

猎头助理

资料完成度 85 %

认证职业身份, 职业经历更可信

认证

我的动态

发布动态

18:05

您好,我这边是猎头顾问,在网上看到您觉得您和我手里的一些岗位契合度比较高,我目前在为各大知名国企、央企招聘,包含技术专家和leader岗位都有HC,如果您考虑机会的话,可以和我聊一聊,不会耽误您太多时间。

我把目前我手里的岗位需求和介绍发给您

好的👍谢谢

您可以给我您的VX吗

下午 6:11

您好

以上是打招呼的内容

下午 6:22

我通过了你的朋友验证请求,现在我们可以开始聊天了

您好

岗位视频详细介绍.zip
21.15MB



微信电脑版

这是我们的本月的岗位视频介绍

您觉得那个岗位合适您,可以和我说说

钓鱼案例3

XXXXXX集团人力资源部

内部文件

关于五一礼品发放通知

各位同事：

大家好！

2022年劳动节即将到来，公司为了感谢全体员工为公司的辛勤工作和奉献，特为大家准备了五一劳动节礼品，请大家注意查收。

一、发放范围：

按照《五一劳动节礼品发放办法》规定，凡在公司工作满一年以上的员工均可参加。请于2022年5月1日前将礼品领取单交回人力资源部，以便统计。

注：凡不参加的员工将视为自动放弃。

二、领取时间：

请于2022年5月1日至5月10日。

领取地点：人力资源部（地址：XXXXXX集团总部大楼）

如有疑问，请咨询人力资源部（电话：XXXXXX）。

特此通知！



附件下载

XXXXXX集团人力资源部

附件(2个)

附件1：五一劳动节礼品发放办法

附件2：五一劳动节礼品领取单

附件3：五一劳动节礼品领取单

XXXXXXXXXX集团通知

XXXXXX集团人力资源部

内部文件

关于五一礼品发放通知

各位同事：

大家好！

2022年劳动节即将到来，公司为了感谢全体员工为公司的辛勤工作和奉献，特为大家准备了五一劳动节礼品，请大家注意查收。

一、发放范围：

按照《五一劳动节礼品发放办法》规定，凡在公司工作满一年以上的员工均可参加。请于2022年5月1日前将礼品领取单交回人力资源部，以便统计。

注：凡不参加的员工将视为自动放弃。

领取时间：2022年5月1日至5月10日。

领取地点：人力资源部（地址：XXXXXX集团总部大楼）

如有疑问，请咨询人力资源部（电话：XXXXXX）。

特此通知！

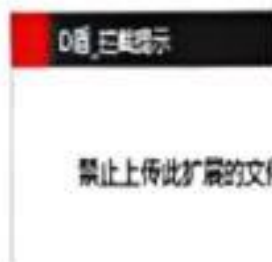


附件下载

XXXXXX集团人力资源部

以上邮件为钓鱼邮件！切勿点击！请全体成员立即下载安全软件进行保护！

判断WAF,便于采取绕过WAF的办法。



您的访问请求可能对网站造成安全威胁，请求已被 长亭 Safelane 拦截。



警告：您的访问可能对网站造成危险，已被云防护安全拦截

判断WAF,便于采取绕过WAF的办法。

493

源IP: 58.44.241.111

eventID: 1249-1581148185.262-waf03ht

抱歉! 您的访问可能对网站造成威胁, 已被云防护拦截!

返回



当前访问疑似黑客攻击, 已被创宇网拦截。

如果您是网站管理员[点击这里](#)查看详情

server: 383baa1, time: [30005]



问题描述

cloudwaf-open 开启了安全防护策略, 您提交的请求被安全防护策略阻止, 可能的操作是: 提交某个请求, SQL命令, 异常数据提交

应对方案

请发送邮件给站长, 报告您被禁止访问的URL, 附件需包含您的请求。

Event ID: 1411000000-0000 源IP: 172.16.17.102 请求时间



501错误

抱歉, 当前页面无法正常访问!

由于您提交的信息对网站可能造成威胁
出于安全考虑, 您的访问被拦截。

报错反馈





感谢观看

